
NORMA DE TRATAMENTO, CLASSIFICAÇÃO E ARMAZENAMENTO DE INFORMAÇÕES

Código:
NT-02

Versão:
1.0

Data de Emissão:
10/11/2025

Público-Alvo:
Público Interno e Externo

Aprovação:
Presidência

1 Objetivo

Garantir que todas as informações da Sentinela Controladoria sejam classificadas e tratadas de forma adequada conforme seu nível de sensibilidade, protegendo sua confidencialidade, integridade e disponibilidade. Esta norma visa estabelecer diretrizes para classificação, manuseio, armazenamento, compartilhamento e descarte de informações, reduzindo riscos de vazamento, acesso não autorizado ou perda de dados. Também busca assegurar conformidade com normas internacionais de segurança da informação e requisitos legais aplicáveis (ex.: LGPD), fortalecendo a cultura de proteção de dados na organização.

2 Escopo

Esta norma se aplica a todas as informações e dados da Sentinela Controladoria, em qualquer formato (digital ou físico), ao público interno (empregados, estagiários, sócios) e ao público externo (prestadores de serviço e parceiros) que tenham acesso ou façam uso dessas informações. Inclui documentos, arquivos eletrônicos, bancos de dados, *e-mails* corporativos, mídias de armazenamento e quaisquer outros ativos de informação utilizados nas operações da Sentinela.

3 Referências Normativas

- 3.1 NIST SP 800-53 Rev. 5: Controles AC e IA;
- 3.2 NIST SP 800-53 Rev. 5: Controles das famílias MP (Media Protection), SC (System and Communications Protection) e AC (Access Control);
- 3.3 NIST SP 800-171 Rev. 2: Requisitos 3.8 (Media Protection) e 3.13 (System and Communications Protection) – Proteção de Informações Controladas Não Classificadas;
- 3.4 ISO/IEC 27002:2022: Seções 5.12 (Classificação da Informação), 5.13 (Rotulagem da Informação), 5.14 (Transferência de Informação), 5.15 (Controle de Acesso), 8.10 (Exclusão de Informações) e 8.11 (Mascaramento de Dados);
- 3.5 LGPD (Lei 13.709/2018): Art. 46 a 50 – Segurança e Boas Práticas.

4 Definições

4.1 Ativo de Informação

Todo os dados ou conjuntos de informações com valor para a empresa que requerem proteção, incluindo documentos em papel, arquivos digitais, bancos de dados, *e-mails*, mídias de *backup* e demais suportes que armazenem informações da Sentinela Controladoria.

4.2 Classificação da Informação

Processo de atribuir um nível de sensibilidade a um ativo de informação, conforme critérios de confidencialidade, integridade e disponibilidade, bem como requisitos legais ou contratuais (ISO/IEC 27002, 5.12). Os níveis padrão são: Pública, Interna, Confidencial e Restrita.

4.3 Rótulo de Classificação

Marcação clara e visível que indica a classificação atribuída a uma informação (ISO/IEC 27002, 5.13).

4.4 Proprietário da Informação

Pessoa ou área designada como responsável por determinado ativo de informação. Compete ao proprietário definir e revisar a classificação da informação, bem como autorizar seu uso e acesso.

4.5 Dados Pessoais

Informação relacionada à pessoa natural identificada ou identificável, direta ou indiretamente.

4.6 Dados Pessoais Sensíveis

Categoria especial de dados pessoais que reflete aspectos mais íntimos do indivíduo, como origem racial/étnica, convicção religiosa, opinião política, filiação a sindicato ou organização, dado referente à saúde ou à vida sexual, dado genético ou biométrico (LGPD, Art. 5º, II). Exigem proteção mais rigorosa devido ao potencial de discriminação ou danos em caso de divulgação indevida.

4.7 Mascaramento de Dados

Técnica de substituição ou ofuscação de valores reais de dados por valores fictícios ou anonimizados, preservando o formato original (ISO/IEC 27002, 8.11).

5 Responsabilidades

As responsabilidades são segregadas por função para assegurar clareza e alinhamento com outras normas da organização.

5.1 Usuários

- 5.1.1 Classificar e rotular corretamente as informações que produzem ou utilizam, usando os níveis definidos nesta norma;
- 5.1.2 Utilizar somente meios corporativos autorizados (repositórios homologados, e-mail corporativo) para armazenar e compartilhar informações;
- 5.1.3 Adotar práticas de mesa e tela limpas; proteger documentos físicos e digitais sob sua custódia;
- 5.1.4 Coletar e utilizar apenas os dados pessoais estritamente necessários, respeitando as bases legais da LGPD; minimizar o acesso ou armazenamentos não essenciais;
- 5.1.5 Revisar permissões quando compartilhar arquivos, revogando acessos quando deixarem de ser necessários;
- 5.1.6 Reportar imediatamente qualquer incidente ou suspeita de violação de segurança à equipe de Tecnologia.

5.2 Proprietários da Informação

- 5.2.1 Definir a classificação inicial de cada ativo e reavaliar periodicamente ou quando houver mudança de risco ou uso;
- 5.2.2 Aprovar acessos, compartilhamentos externos e transferências internacionais de informações, observando contratos e leis;
- 5.2.3 Assegurar que os ativos sob sua responsabilidade estejam devidamente rotulados (física e digitalmente) e possuam tabela de retenção definida;
- 5.2.4 Verificar que o tratamento de dados pessoais cumpre com os princípios de finalidade, necessidade e transparência previstos pela LGPD.

5.3 Gestores

- 5.3.1 Garantir que sua equipe cumpra esta Norma e receba treinamento e conscientização adequados sobre classificação e proteção de dados;
- 5.3.2 Aprovar pedidos de acesso conforme as funções, seguindo o princípio do menor privilégio;
- 5.3.3 Comunicar mudanças organizacionais (transferências, desligamentos) que impactem na classificação ou no acesso às informações;
- 5.3.4 Apoiar auditorias e inventários de dados e colaborar com ações corretivas.

5.4 Equipe de Tecnologia da Informação

- 5.4.1 Disponibilizar repositórios corporativos e modelos de rótulos de classificação, garantindo sua atualização e conformidade;
- 5.4.2 Aplicar controles técnicos de proteção: criptografia em repouso e em trânsito, detecção e prevenção de vazamentos (DLP), autenticação multifator, registros de acesso, cópias de segurança (*backups*) e sanitização de mídias;
- 5.4.3 Garantir mascaramento ou anonimização de dados em ambientes de desenvolvimento e testes;
- 5.4.4 Monitorar e auditar o cumprimento desta norma; apoiar investigações e correções de incidentes.

6 Diretrizes de Tratamento, Classificação e Armazenamento

6.1 Níveis de Classificação

6.1.1 Pública

Informação destinada ao público; sua divulgação não causa impacto relevante.

6.1.2 Interna

Uso interno; divulgação externa sem autorização pode causar impacto operacional ou competitivo.

6.1.3 Confidencial

Acesso restrito a grupos ou áreas; vazamento pode causar impacto financeiro ou reputacional significativo.

6.1.4 Restrita

Acesso altamente limitado (*need-to-know*); divulgação não autorizada pode causar dano crítico (sanções legais, fraude, quebra de sigilo)

6.2 Critérios de Classificação

Atribuir um nível de acordo com o impacto causado em:

- 6.2.1 Confidencialidade, Integridade, Disponibilidade;
- 6.2.2 Requisitos legais ou contratuais (LGPD, acordos de confidencialidade);
- 6.2.3 Impacto ao negócio em caso de exposição ou perda;
- 6.2.4 Princípio *need-to-know*, limitando acesso ao estritamente necessário.

6.3 Rotulagem e Marcação

6.3.1 Documentos digitais

Incluir o rótulo de classificação em cabeçalhos/rodapés e nos metadados.

6.3.2 E-mails

Prefixar o assunto quando a informação for Interna/Confidencial/Restrita (ex.: “[Confidencial] ...”).

6.3.3 Documentos Físicos

Usar etiquetas ou capas com o nível de classificação; aplicar marcas d’água para Confidencial/Restrita.

6.3.4 Sistemas e Relatórios

Registrar o campo de classificação em sistemas (ERP, BI) e preservar a herança da classificação em relatórios exportados.

6.4 Manuseio por Classe

6.4.1 Pública

Uso e armazenamento livre em repositórios autorizados.

6.4.2 Interna

Armazenar apenas em repositórios corporativos; compartilhamentos externos exigem autorização do gestor.

6.4.3 Confidencial

Obrigatória a criptografia em repouso e em trânsito; compartilhamento externo apenas com acordo de confidencialidade e controle de acesso nominal; anexos devem ser protegidos (senha ou criptografia) com senha enviada por canal distinto.

6.4.4 Restrita

Acesso somente mediante autorização formal e registrado; proibido uso de mensagerias não corporativas; armazenamento restrito a repositórios homologados com DLP e registros de acesso; evitar impressão; quando necessário, garantir rastreabilidade e guarda segura.

6.5 Transferência e Compartilhamento

6.5.1 Interno

Utilizar *e-mail* corporativo, compartilhamento via repositórios autorizados ou links com controle de acesso e expiração.

6.5.2 Externo

Requer autorização do Proprietário ou Gestor, acompanhamento de acordos de confidencialidade ou termos de processamento de dados; anexos devem ser criptografados e a senha comunicada por canal separado.

6.5.3 Transferência Internacional

Observar a legislação vigente aplicável (LGPD), incluindo cláusulas contratuais específicas.

6.6 Retenção e Descarte

- 6.6.1 Seguir a tabela de temporalidade aprovada pelas áreas responsáveis e requisitos legais; *backups* devem seguir as diretrizes de retenção da NT-SI-03;
- 6.6.2 Garantir exclusão lógica irrecuperável para mídias digitais; trituração ou destruição segura para documentos físicos;
- 6.6.3 Registrar formalmente o descarte de mídias e documentos, indicando data, responsável e tipo de informação descartada.

6.7 Impressão, Cópias e Digitalização

- 6.7.1 Reduzir impressões ao mínimo; para informações Confidenciais ou Restritas, imprimir somente quando estritamente necessário;
- 6.7.2 Cópias físicas e digitais herdam o mesmo nível de classificação do documento original.

7 Comunicação de Incidentes

Qualquer incidente, suspeita ou evidência de violação desta norma deve ser comunicado imediatamente à equipe de Tecnologia. Isso inclui, mas não se limita a: envio acidental de informação Confidencial/Restrita para destinatário incorreto; perda, roubo ou extravio de documentos ou dispositivos contendo informações sensíveis; acesso não autorizado detectado a sistemas ou arquivos confidenciais; ou qualquer situação em que informações classificadas possam ter sido comprometidas. A notificação rápida possibilita acionar a Norma de Resposta a Incidentes e *Backup* (NT-SI-03) para contenção, investigação e reporte adequado, minimizando impactos negativos. Os colaboradores devem cooperar fornecendo detalhes do incidente e seguindo as orientações da equipe de Segurança para remediação.

8 Sanções

O descumprimento desta norma constitui falta grave e poderá resultar em medidas disciplinares, conforme o código de conduta da empresa. As sanções incluem, de forma gradual: advertência verbal ou escrita, suspensão, desligamento por justa causa, e, se cabível, medidas legais (cíveis e penais) contra os responsáveis. A Sentinela Controladoria poderá adotar ações legais nos casos de vazamento intencional de informações ou negligência grave na proteção de dados, em conformidade com a legislação vigente e contratos de trabalho. (ISO/IEC 27002, 5.35).

9 Revisão e Atualização

Esta norma será revisada anualmente ou sempre que ocorrerem mudanças relevantes no ambiente de negócios, nas tecnologias utilizadas, nos requisitos legais/regulatórios de proteção de dados ou nas melhores práticas internacionais que possam afetar as diretrizes aqui estabelecidas. A revisão é de responsabilidade do Comitê de Segurança da Informação em conjunto com a Presidência da Sentinela.